Microsoft Purview for Retail

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview for Retail 5

The retail posture — stated plainly . . . 5

What you get . . . 5

The standard deployment model . . . 5

Outcome . . . 5

1. Solution Overview — Microsoft Purview for Retail 6

What this solution is . . . 6

The Purview capabilities used . . . 6

How it works . . . 7

What you can control . . . 7

Benefits . . . 7

Limitations (be honest with buyers) . . . 7

The standard deployment model . . . 8

2. Requirements Guide — Microsoft Purview for Retail 8

2.1 Microsoft 365 + Purview compliance licensing (PCI/PII features) . . . 8

2.2 Least-privilege Purview roles . . . 8

2.3 Retail data map and PCI-scope decision (owner-provided) . . . 8

2.4 Retail sensitivity-label taxonomy defined . . . 9

2.5 Sensitive-information types confirmed (PAN + customer PII) . . . 9

2.6 Pilot scope (users and, for endpoint DLP, devices) . . . 9

2.7 Endpoint onboarding (endpoint DLP only) . . . 9

2.8 Audit logging enabled . . . 9

2.9 Change control for enforce-mode and retention deletion . . . 10

Checklist . . . 10

Global Requirements — Microsoft Purview Solutions 10

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 11

2. Purview roles (least-privilege) and portal access . . . 11

3. Security & Compliance PowerShell + Graph toolchain . . . 11

4. Data sources & scope in scope . . . 11

5. Compliance, records, privacy & legal stakeholders . . . 12

6. A pilot scope and change control . . . 12

3. Implementation Guide — Microsoft Purview for Retail 12

Step 1 — Design the retail label taxonomy (Assess/Design) . . . 13

Step 2 — Create the sensitivity labels . . . 14

Step 3 — Publish the labels with a label policy . . . 14

Step 4 — Configure auto-labeling in SIMULATION (find the data) . . . 14
Step 5 — Build the PCI DLP policy in TEST/AUDIT mode . . . 15
Step 6 — Build the customer-PII DLP policy in TEST/AUDIT mode . . . 15
Step 7 — Pilot and tune (the DLP audit gate) . . . 15
Step 8 — Switch DLP to ENFORCE / BLOCK (after the gate) . . . 16
Step 9 — Create retention labels (retail records + payment minimization) . . . 16
Step 10 — Create a retention policy (baseline) . . . 16
Step 11 — Stand up the PCI-DSS compliance baseline (evidence) . . . 17
Step 12 — Validate, then expand . . . 17
5. Testing Guide — Microsoft Purview for Retail 17
Test 1 — Labels published and visible . . . 18
Test 2 — Label protection applies . . . 18
Test 3 — Auto-labeling simulation finds PAN . . . 18
Test 4 — PCI DLP is auditing (before the gate) . . . 18
Test 5 — Customer-PII DLP is auditing (before the gate) . . . 18
Test 6 — PCI DLP blocks (after the gate) . . . 18
Test 7 — Customer-PII DLP enforces (after the gate) . . . 18
Test 8 — Endpoint DLP fires (endpoint DLP only) . . . 18
Test 9 — Retention label applied and honored . . . 19
Test 10 — Retention policy scoped . . . 19
Test 11 — PCI compliance evidence present . . . 19
Test 12 — Coverage report . . . 19
Pass/fail gate . . . 19
6. Troubleshooting Guide — Microsoft Purview for Retail 19
A. Sensitivity labels not appearing for retail users . . . 20
B. Auto-labeling not finding cardholder data . . . 20
C. PCI/PII DLP is too noisy (false positives) . . . 20
D. DLP not blocking after enforce . . . 21
E. Cardholder data still found in M365 after enforcement . . . 21
F. Retention deleting too much or nothing . . . 21
G. PCI-DSS Compliance Manager template missing . . . 21
H. Licensing / feature missing . . . 22
I. Diagnostics quick reference . . . 22
J. When to escalate . . . 22
7. Best Practices — Microsoft Purview for Retail 22
8. Deliverables Summary — Microsoft Purview for Retail 23

Documentation 23
PowerShell scripts 24
What the buyer receives 24
Outcome 24
Appendix A — PowerShell Scripts 26

Executive Summary — Microsoft Purview for Retail

White-label · Industry (Retail · PCI-DSS)

Retail runs on customer data — names, contact and address details, purchase and loyalty history — and touches payment card data at every point of sale. That combination carries specific obligations: **PCI-DSS** for cardholder data and privacy law for customer personal data. The common failure is not a lack of tools but data that is never classified, never contained, and never retained on a defined schedule — so a stray Primary Account Number (PAN) ends up in an email or a SharePoint site, quietly pulling a general-productivity system into PCI scope, and customer data leaves through an endpoint nobody was watching.

This is a complete, deploy-it-in-order package that configures **Microsoft Purview** into a **Retail-tailored data-protection program**: a small sensitivity-label taxonomy, auto-labeling that maps where cardholder data actually lives, **Data Loss Prevention** built from Microsoft's PCI-DSS and PII templates and tuned in audit before it blocks, retention that meets the retail records schedule while minimizing payment-data storage, and a **PCI-DSS compliance baseline** in Compliance Manager for evidence. It is written for an administrator with no prior Purview experience.

The retail posture — stated plainly

For most retailers, Microsoft 365 should stay **out** of PCI-DSS scope. This solution uses Purview to **keep it that way** — detecting and blocking PAN from landing in email, collaboration, and endpoints — while **protecting and retaining** the customer PII that legitimately does live there. Purview does not turn Microsoft 365 into a certified cardholder-data environment; the segmented payment environment stays separate. **PCI scope, applicable requirements, and retention periods are compliance/QSA/records determinations** — this package delivers the technical configuration and the evidence, not the ruling.

What you get

- A plain-language Solution Overview of the retail Purview program and how its parts work together.
- A Requirements Guide with verify / implement-if-missing for every retail-/PCI-specific prerequisite.
- An Implementation Guide of precise, ordered steps in the Microsoft Purview portal.
- Five PowerShell scripts: discovery, a safe configuration/remediation helper (`-WhatIf` first),

validation, a classification/DLP coverage report, and a pilot-scope/health helper.

- Testing and Troubleshooting guides for a confident rollout.

The standard deployment model

Assess → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)** — with a mandatory DLP audit gate before any policy blocks, auto-labeling simulated before it labels, retention piloted before it deletes, and a documented rollback.

Outcome

A Retail-tailored Purview program that is configured, piloted, validated, and evidenced against PCI-DSS — cardholder data blocked from Microsoft 365, customer PII protected and retained, and the program defensible to an auditor — proven on a pilot before you scale.

1. Solution Overview — Microsoft Purview for Retail

What this solution is

Retail organizations handle two kinds of data that carry specific obligations: **payment card data** (cardholder data — primarily the **Primary Account Number / PAN**) governed by **PCI-DSS**, and a large volume of **customer personal data** (names, contact details, addresses, purchase and loyalty history) governed by privacy law. This solution configures **Microsoft Purview** — sensitivity labels, Data Loss Prevention (DLP), retention/records, and a PCI-DSS compliance baseline — into a **Retail-tailored data-protection program** across Microsoft 365 and managed endpoints.

The retail-specific goal is deliberate and defensible: **keep payment card data out of Microsoft 365 where it does not belong, protect the customer PII that legitimately lives there, and retain both on a defined schedule** — so a cardholder-data leak or an over-retention finding is prevented and the program is evidenced against PCI-DSS.

> ***The PCI-DSS posture this solution takes (be explicit).*** *For most retailers, general-productivity systems (Exchange, SharePoint, OneDrive, Teams, endpoints) are* ***out of PCI-DSS scope*** *and should* ***stay*** *out of scope — cardholder data belongs in the segmented, PCI-certified payment environment, not in email or a SharePoint site. Purview's role here is to* ***detect and block PAN*** *from landing in these systems (keeping them out of scope) and to* ***protect and retain*** *the customer PII that legitimately does.* ***What data is in PCI scope, the applicable PCI-DSS requirements, and the required retention periods are compliance/legal determinations*** *made by the organization's QSA / compliance, records, and privacy functions — this solution provides the* ***technical configuration and evidence****, not the determination.*

The Purview capabilities used

1. **Sensitivity labels** — persistent tags for retail data (`Retail Public`, `Retail Internal`, `Customer PII - Confidential`, `Cardholder Data - Restricted`) that mark and, where appropriate, encrypt content and travel with the file.
1. **Data Loss Prevention (DLP)** — policies built from Microsoft's **PCI Data Security Standard** and **PII** templates plus the **Credit Card Number** sensitive-information type, deployed first in **test/audit** and tuned before they **block** the movement of PAN and customer PII across Exchange, SharePoint, OneDrive, Teams, and endpoints.
1. **Retention & records** — labels and policies that keep transaction and customer records for the required period and dispose of them defensibly, and that minimize storage of any cardholder data in line with PCI-DSS's data-minimization principle.
1. **Compliance baseline** — a **Microsoft Purview Compliance Manager** assessment using the **PCI-DSS**

template (licensing-dependent) to track technical controls and produce evidence.

How it works

1. You agree a small retail label taxonomy with data owners and publish it to a pilot group.

2. Auto-labeling runs in **simulation** to find where cardholder data and customer PII actually live.

3. DLP policies (PCI + PII) run in **test/audit** on the pilot; you review the matches (the **DLP audit gate**), tune out false positives, and only then switch to** block**.

1. Retention labels/policies set how long retail records live and enforce data minimization for any cardholder data.

1. Compliance Manager tracks the PCI-related technical controls; every action is logged for reporting.

What you can control

• The retail label taxonomy and the protection each label applies (marking, encryption, sharing limits).

• DLP scope (Exchange, SharePoint, OneDrive, Teams, endpoints), which sensitive-information types and labels each policy matches (PAN, PII), and the action (audit → block).

• Retention duration, trigger, and end-of-life action for retail records; records/disposition review.

• Which PCI-DSS controls Compliance Manager tracks and evidences.

Benefits

• **PCI scope kept small** — DLP blocks PAN from reaching email/collaboration/endpoints, so those systems stay out of PCI scope rather than being dragged into it by stray cardholder data.

• **Customer PII protected** — labels and DLP protect the personal data retail legitimately holds, reducing breach and privacy exposure.

• **Defensible retention** — retail records are kept and disposed of on a defined schedule; cardholder data storage is minimized.

• **Evidenced compliance** — classification, DLP events, and PCI controls are reportable for auditors.

Limitations (be honest with buyers)

• Auto-labeling at rest, endpoint DLP, and Compliance Manager premium (PCI-DSS) templates require **Microsoft 365 E5** or the **E5 Compliance** add-on — the Requirements Guide names the licensing; **verify your licensing/tenant**.

• Purview does **not** make Microsoft 365 a PCI-compliant cardholder-data environment. It reduces the chance cardholder data lands there; the certified payment environment remains separate.

• DLP detects PAN with high accuracy but not perfectly (Luhn-checked patterns); the audit gate exists

to tune before enforcing.

- Retention deletion is irreversible once the period elapses; validate on a pilot first.
- Regulatory/PCI/records determinations are made by compliance/QSA/legal, not by this configuration.

The standard deployment model

> ***Assess*** → ***Design*** → ***Configure*** → ***Pilot (simulate/test)*** → ***Validate*** → ***Expand (enforce)*** — *DLP runs in audit before it blocks (the DLP audit gate), auto-labeling runs in simulation before it labels, and retention is piloted before it deletes, each with explicit pass/fail gates and a documented rollback.*

2. Requirements Guide — Microsoft Purview for Retail

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-purview.md` (the six shared Purview requirements — licensing, roles, S&C PowerShell/Graph toolchain, in-scope data, the compliance/records/privacy/legal stakeholders, and a pilot scope with change control). The entries below are the **retail-/PCI-specific** additions on top of those.

2.1 Microsoft 365 + Purview compliance licensing (PCI/PII features)

Description: Licensing that covers the features this solution uses. Sensitivity labels and basic DLP ship in **Microsoft 365 E3 / Business Premium**; **auto-labeling at rest, endpoint DLP, advanced records management, and Compliance Manager premium assessment templates (including PCI-DSS)** require **Microsoft 365 E5** or the **E5 Compliance** add-on. **Why:** The PCI cardholder-data detection at scale (auto-labeling/endpoint DLP) and the PCI-DSS Compliance Manager template are plan-gated; they will not appear without the higher plan. **Verify:** M365 admin center → **Billing** → **Licenses**; confirm the PCI-DSS template is offered in Purview → **Compliance Manager** → **Assessment templates**. Run `RETAIL-Discovery.ps1`. **Verify your licensing/tenant** — availability evolves. **Implement:** Assign E3/Business Premium for labels + basic DLP; add E5 or the E5 Compliance add-on for auto-labeling at rest, endpoint DLP, and the PCI-DSS Compliance Manager template.

2.2 Least-privilege Purview roles

Description: The operator holds the least-privilege roles to create labels, DLP, and retention — **Compliance Administrator** (or **Information Protection Admin** + **Data Loss Prevention** roles), and **Compliance Manager** access for the PCI assessment. Global Administrator only where genuinely required. **Why:** Purview uses fine-grained role groups; configuration requires the matching role, and least-privilege is a PCI-DSS control in itself. **Verify:** `https://purview.microsoft.com` → **Settings** → **Roles and scopes** → **Role groups**; confirm membership. **Implement:** Assign the least-privilege role group under change control; reserve Global Administrator for tenant-wide changes.

2.3 Retail data map and PCI-scope decision (owner-provided)

Description: A statement, from the compliance/QSA and data owners, of **what customer and payment data exists**, where it lives, and **which systems are in PCI-DSS scope** — and the confirmation that Microsoft 365 (Exchange/SharePoint/OneDrive/Teams/endpoints) is intended to be **out** of PCI scope (no

cardholder data stored there). **Why:** DLP conditions and retention durations follow the retail data map and the scope decision, not IT defaults; **the PCI-scope determination is a compliance/QSA decision**, not a technical one. **Verify:** A one-page data map exists (data type → system → PCI in/out-of-scope → owner). **Implement:** Work with compliance/QSA and data owners to capture the data map and the scope decision before authoring policies.

2.4 Retail sensitivity-label taxonomy defined

Description: A short, agreed label set with a clear meaning for each — the taxonomy this solution publishes: `Sensitivity Label - Retail Public`, `Sensitivity Label - Retail Internal`, `Sensitivity Label - Customer PII - Confidential`, `Sensitivity Label - Cardholder Data - Restricted`. **Why:** Labels only work if store, e-commerce, and head-office staff understand them; too many labels confuse, too few under-protect. **Verify:** A one-page taxonomy exists (label name, meaning, protection, who applies it). **Implement:** Agree the 4-label taxonomy with data owners before configuring (Implementation Step 1).

2.5 Sensitive-information types confirmed (PAN + customer PII)

Description: The Purview **sensitive-information types (SITs)** the policies key off — the built-in **Credit Card Number** SIT (Luhn-validated) for PAN, and the country PII SITs relevant to your customers (for example national ID, passport, driver's licence, and address/email patterns). **Why:** DLP and auto-labeling match on these SITs; the wrong SITs mean missed PAN or PII noise. **Verify:** Purview → **Data classification** → **Sensitive info types**; confirm **Credit Card Number** and the relevant country PII SITs exist. Run `RETAIL-Discovery.ps1`. **Implement:** Use the built-in SITs; add custom SITs (for example a loyalty-ID pattern) only if a data owner defines the pattern.

2.6 Pilot scope (users and, for endpoint DLP, devices)

Description: A Microsoft Entra security group of pilot users — `Purview - Retail Pilot` — and, for endpoint DLP, retail workstations onboarded to Microsoft Purview. **Why:** Every policy is piloted before rollout; PCI/PII DLP in particular must run in audit on a pilot before it can block safely (a false block at a checkout or fulfilment desk is disruptive). **Verify:** Entra → **Groups** — `Purview - Retail Pilot` exists. Purview → **Settings** → **Device onboarding** shows pilot devices (endpoint DLP only). Run `RETAIL-Set-Scope.ps1`. **Implement:** Build the pilot group with `RETAIL-Set-Scope.ps1`; onboard pilot devices via the Purview device-onboarding package.

2.7 Endpoint onboarding (endpoint DLP only)

Description: Windows devices (for example back-office and head-office workstations that handle customer exports) onboarded to Microsoft Purview so endpoint DLP can monitor file activity (copy to USB, upload to a browser, print). **Why:** Endpoint DLP conditions require onboarded devices; un-onboarded devices are invisible to it — and endpoints are a common path for a customer-data or PAN export to leave. **Verify:** Purview → **Settings** → **Device onboarding** → **Devices**. Run `RETAIL-Discovery.ps1`. **Implement:** Deploy the onboarding configuration (Intune or the script package) to the pilot group.

2.8 Audit logging enabled

Description: Microsoft Purview audit (unified audit log) is on. **Why:** DLP tuning, PCI evidence, and coverage reporting read audit/activity data; without it you cannot review the audit gate or evidence controls. **Verify:** Purview → **Audit**; a search returns results. Run `RETAIL-Report.ps1`. **Implement:** Turn on auditing in the Purview **Audit** solution; allow time for events to populate.

2.9 Change control for enforce-mode and retention deletion

Description: A documented change-control / rollback process for switching any DLP policy from audit to **block**, or for activating a retention policy that **deletes** retail records. **Why:** A block at a retail operations desk can halt legitimate work and retention deletion is irreversible; a pilot gate and rollback are mandatory. **Verify:** A change ticket exists with an approver, the pilot scope, and a documented rollback (revert DLP to test/audit; disable the retention policy). **Implement:** Record the change, name the pilot scope, define the rollback, and get approval before enforcing.

Checklist

- M365 + Purview licensing (E3/Business Premium for labels + basic DLP; E5/E5 Compliance for auto-labeling at rest, endpoint DLP, PCI-DSS Compliance Manager) — `RETAIL-Discovery.ps1` · **verify your licensing/tenant**
- Least-privilege Purview roles assigned (Compliance Administrator / Information Protection + DLP; Compliance Manager)
- Retail data map + PCI-scope decision captured (owner/QSA-provided)
- Retail 4-label taxonomy defined
- Sensitive-info types confirmed — Credit Card Number (PAN) + relevant country PII — `RETAIL-Discovery.ps1`
- Pilot group `Purview - Retail Pilot` created — `RETAIL-Set-Scope.ps1`
- Endpoint devices onboarded (endpoint DLP only) — `RETAIL-Discovery.ps1`
- Purview audit logging enabled — `RETAIL-Report.ps1`
- Change control + rollback for enforce-mode / retention deletion

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or***

***flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

- **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

- **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

- **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

- **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview for Retail

Follow these steps **in order**, in the **Microsoft Purview portal** (`https://purview.microsoft.com`). Portal paths are current at authoring; the portal evolves — if a path differs, **verify against Microsoft's current documentation**, do not guess.

> ***Model:*** *Design a small retail label taxonomy, publish it, run auto-labeling in* ***simulation*** *to find where PAN and customer PII live, build PCI + PII DLP in* ***test/audit*** *and tune it (the* ***DLP audit gate****) before it* ***blocks****, then set retention and stand up the PCI-DSS compliance baseline — piloting each on* `Purview - Retail Pilot` *before you expand. Pattern: Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand (enforce).*

The named objects created below are reused verbatim in Testing, Troubleshooting, and the scripts:

Object	Name
Sensitivity labels	`Sensitivity Label - Retail Public`, `Sensitivity Label - Retail Internal`, `Sensitivity Label - Customer PII - Confidential`, `Sensitivity Label - Cardholder Data - Restricted`
Label policy	`Label Policy - Retail Data Classification - Pilot`
Auto-labeling policy	`Auto-Label - PCI Cardholder Data - Simulation`
DLP policy (PCI)	`DLP Policy - Retail PCI Cardholder Data - Test` (renamed to `... - Enforce` at the gate)
DLP policy (PII)	`DLP Policy - Retail Customer PII - Test` (renamed to `... - Enforce` at the gate)
Retention label (payment)	`Retention Label - Payment Records - 18 Month`
Retention label (transaction)	`Retention Label - Customer Transaction Records - 7 Year`
Retention policy	`Retention Policy - Retail Baseline - 5 Year`
Compliance assessment	`Assessment - PCI-DSS - Retail Baseline`
Pilot scope group	`Purview - Retail Pilot`

> ***Retention periods are examples only.*** `18 Month` / `7 Year` / `5 Year` *are placeholders — the* ***actual retail records schedule and any PCI-DSS retention/minimization requirement are set by the compliance/records/legal function****, not by IT. Replace them with the approved values.*

Step 1 — Design the retail label taxonomy (Assess/Design)

1. With the data owners and compliance, agree the four labels and the protection each applies:

• `Sensitivity Label - Retail Public` — marketing/public content; no protection; shareable externally.

• `Sensitivity Label - Retail Internal` — internal retail/business data; no encryption.

• `Sensitivity Label - Customer PII - Confidential` — customer personal data; encrypt, restrict to

the organization.

• `Sensitivity Label - Cardholder Data - Restricted` — any cardholder data (PAN); encrypt, restrict

to a named group, marked so it is unmistakable and **should not be in M365 at all**.

1. Record each label's meaning, protection, and who applies it (the taxonomy from Requirement 2.4).

Step 2 — Create the sensitivity labels

1. Purview portal → **Information Protection** → **Sensitivity labels** → **Create a label**.

2. **Name and tooltip:** enter the label name (for example `Sensitivity Label - Cardholder Data - Restricted`) and a user-facing tooltip. **Next**.

1. **Scope:** select **Items** (files and emails). **Next**.

2. **Encryption:** choose **Configure encryption** for `Customer PII - Confidential` (permit **All Users in <org>) and `Cardholder Data - Restricted` (permit only a named restricted group). Leave `Retail Public` / `Retail Internal` without encryption.** Next**.

1. **Content marking:** add a header/footer/watermark where required (for example `RESTRICTED — CARDHOLDER DATA` on the cardholder-data label). **Next**.

1. **Auto-labeling for items:** leave off here (configured centrally in Step 4). **Next → Create the label**.

1. Repeat for each label, creating them in sensitivity order (`Retail Public` → `Retail Internal` → `Customer PII - Confidential` → `Cardholder Data - Restricted`). Label order sets priority.

Step 3 — Publish the labels with a label policy

1. Purview portal → **Information Protection** → **Sensitivity labels** → **Label policies** → **Publish labels**.

2. **Choose labels to publish:** add all four taxonomy labels. **Next**.

3. **Assign to users and groups:** add `Purview - Retail Pilot` for the pilot. **Next**.

4. **Policy settings:** require a justification for downgrading a label; optionally require a label for new items. **Next**.

1. **Default label:** set a default (for example `Retail Internal`) if the org wants one. **Next**.

2. **Name:** `Label Policy - Retail Data Classification - Pilot`. **Next** → **Submit**.

Step 4 — Configure auto-labeling in SIMULATION (find the data)

1. Purview portal → **Information Protection** → **Auto-labeling** → **Create auto-labeling policy**.

2. **Choose the information to label:** pick the **PCI Data Security Standard (PCI DSS)** template or **Custom**. **Next**.

1. **Name:** `Auto-Label - PCI Cardholder Data - Simulation`. **Next**.

2. **Locations:** select **Exchange email**, **SharePoint sites**, **OneDrive accounts** as needed; scope to pilot locations. **Next**.

1. **Rules:** set the condition to the **Credit Card Number** sensitive-information type and set the label to apply to `Sensitivity Label - Cardholder Data - Restricted`. **Next**.

1. **Test the policy first:** choose **Run policy in simulation mode** — do **not** turn it on. **Next** → **Create**. Review the simulation matches: **these show where PAN is sitting in M365** — the input to your PCI-scope and remediation decisions.

Step 5 — Build the PCI DLP policy in TEST/AUDIT mode

1. Purview portal → **Data Loss Prevention** → **Policies** → **Create policy**.

2. **Category / template:** choose the **PCI Data Security Standard (PCI DSS)** template. **Next**.

3. **Name:** `DLP Policy - Retail PCI Cardholder Data - Test`. **Next**.

4. **Locations:** enable **Exchange email**, **SharePoint sites**, **OneDrive accounts**, **Teams chat and channel messages**, **and** Devices **(endpoint DLP) as licensed. Scope to** `Purview - Retail Pilot` **where the location supports user scoping.** Next**.

1. **Rules:** keep the template rule matching the **Credit Card Number** SIT (optionally also the `Cardholder Data - Restricted` label). Set actions to **audit only** — enable **policy tips** for visibility but do **not** block. **Next**.

1. **Policy mode:** select **Run the policy in test mode** (with policy tips). **Next** → **Submit**. The policy now audits PAN movement without blocking.

Step 6 — Build the customer-PII DLP policy in TEST/AUDIT mode

1. Purview portal → **Data Loss Prevention** → **Policies** → **Create policy**.

2. **Template:** choose the country **PII / Personal Data** template relevant to your customers (or **Custom**). **Next**.

1. **Name:** `DLP Policy - Retail Customer PII - Test`. **Next**.

2. **Locations:** enable the same locations as Step 5; scope to `Purview - Retail Pilot`. **Next**.

3. **Rules:** match the relevant country PII SITs and/or the `Customer PII - Confidential` label; set actions to **audit only** with policy tips. **Next**.

1. **Policy mode: Run the policy in test mode**. **Next** → **Submit**.

Step 7 — Pilot and tune (the DLP audit gate)

1. Let both test-mode policies run against `Purview - Retail Pilot` for the agreed window.

2. Review matches in Purview → **Data Loss Prevention** → **Alerts** and **Activity explorer**; run `RETAIL-Report.ps1` for a classification and DLP-event summary by workload.

1. Tune the rules to remove false positives (raise confidence, require a higher instance count, add exceptions for legitimate patterns such as order numbers that resemble a PAN).

1. **Gate:** only when the audit shows the policies match real PAN / customer PII and not routine retail work do you proceed to enforce (Step 8). If still noisy, keep tuning — do **not** enforce.

Step 8 — Switch DLP to ENFORCE / BLOCK (after the gate)

1. Purview portal → **Data Loss Prevention** → **Policies** → open `DLP Policy - Retail PCI Cardholder Data - Test → **Edit.** Rename it to DLP Policy - Retail PCI Cardholder Data - Enforce`.

1. **Rules:** change the PCI rule action to **Block** (PAN should not move through M365 at all — block outright, not block-with-override, unless the business defines a controlled exception). Keep policy tips on. **Next**.

1. **Policy mode: Turn the policy on**. **Next** → **Submit**.

2. Repeat for the PII policy → rename to `DLP Policy - Retail Customer PII - Enforce`; set **Block with override **(or Block) per the business decision;** Turn the policy on**.

1. Enforcement now applies to the pilot scope first; widen the scope in Step 12.

2. **Rollback (if needed):** set the policy mode back to **Test mode** (audit) or turn the policy off.

Step 9 — Create retention labels (retail records + payment minimization)

1. Purview portal → **Data Lifecycle Management** → **Retention labels** → **Create a label**.

2. Create `Retention Label - Customer Transaction Records - 7 Year`: **Retain items for** 7 years from creation, then **Delete** (or **Mark as a record** if immutability is required). **Create**.

1. Create `Retention Label - Payment Records - 18 Month`: a **short** retention that supports PCI-DSS **data minimization** — keep only as long as the business/legal requirement demands, then delete. **Create**.

1. **Replace the durations** with the compliance/records-approved values (Requirement 2.3).

Step 10 — Create a retention policy (baseline)

1. Purview portal → **Data Lifecycle Management** → **Retention policies** → **New retention policy**.

2. **Name:** `Retention Policy - Retail Baseline - 5 Year`. **Next**.

3. **Locations:** enable **Exchange mailboxes**, **SharePoint sites**, **OneDrive accounts**, and

Teams as required. Scope to `Purview - Retail Pilot` for the pilot. **Next**.

1. **Retention settings: Retain items for** 5 years then delete or retain-only per the schedule.

Next → **Submit**.

1. For regulatory records, configure **Records Management** → **File plan** and enable **disposition review** so deletions are reviewed, not automatic.

Step 11 — Stand up the PCI-DSS compliance baseline (evidence)

1. Purview portal → **Compliance Manager** → **Assessments** → **Add assessment**. Choose the **PCI-DSS**

template (premium template — **verify your licensing/tenant**; requires E5 Compliance).

1. **Name:** `Assessment - PCI-DSS - Retail Baseline`. Assign the in-scope group/product. **Create**.

2. Work the improvement actions that map to the Purview controls configured above (classification, DLP, retention) and record evidence. **The PCI-DSS applicability and control ownership are determined by compliance/QSA** — Compliance Manager tracks and evidences, it does not certify.

Step 12 — Validate, then expand

1. Complete the Testing Guide against `Purview - Retail Pilot`.

2. Run `RETAIL-Validation.ps1` (labels published, both DLP policies present, retention present) and

`RETAIL-Report.ps1` (classification + DLP-event coverage).

1. Widen scope: republish `Label Policy - Retail Data Classification - Pilot`, the two DLP enforce

policies, and the retention policy from `Purview - Retail Pilot` to broader groups (or **All users** / **All locations**) once the pilot passes. Turn auto-labeling on (out of simulation) only after its simulation is clean.

1. Re-validate each expansion with `RETAIL-Validation.ps1` and `RETAIL-Report.ps1`.

Order of operations

`Taxonomy → labels → label policy → auto-label (simulation) → PCI DLP (audit) + PII DLP (audit) → audit gate → DLP (enforce/block) → retention labels → retention policy/records → PCI Compliance Manager → validate → expand`

5. Testing Guide — Microsoft Purview for Retail

Run after publishing to `Purview - Retail Pilot` (Implementation Step 3 onward), before the DLP audit gate (Step 7), and again after each expansion. Use **synthetic/test data only** — never a real PAN or real customer record. Microsoft publishes test card numbers (for example the Luhn-valid test PAN `4111 1111 1111 1111`) safe to use for DLP validation.

Test 1 — Labels published and visible

Do: In Outlook / Word (web or desktop) as a pilot user, open the **Sensitivity** button. Or run `RETAIL-Validation.ps1`. **Expected:** All four taxonomy labels appear (`Sensitivity Label - Retail Public` through `Sensitivity Label - Cardholder Data - Restricted`) via `Label Policy - Retail Data Classification - Pilot`.

Test 2 — Label protection applies

Do: Apply `Sensitivity Label - Customer PII - Confidential` to a test document and try to open it as an out-of-scope external user. **Expected:** The document is encrypted/marked; the external user is denied per the label's permissions.

Test 3 — Auto-labeling simulation finds PAN

Do: Purview → **Information Protection** → **Auto-labeling** → open `Auto-Label - PCI Cardholder Data - Simulation` → **Simulation**. **Expected:** The simulation lists items containing card-number patterns (your seeded test files) and does not flag routine, non-sensitive content — this is your map of where PAN sits in M365.

Test 4 — PCI DLP is auditing (before the gate)

Do: As a pilot user, email a message containing a **test** card number to an external address; check Purview → **Data Loss Prevention** → **Alerts** and **Activity explorer**. Or run `RETAIL-Report.ps1`. **Expected:** `DLP Policy - Retail PCI Cardholder Data - Test` records the match (policy tip shown, no block) — the audit gate has data to review.

Test 5 — Customer-PII DLP is auditing (before the gate)

Do: As a pilot user, share a test file containing seeded customer PII (test names/IDs) to an external recipient; check Alerts / Activity explorer. Or run `RETAIL-Report.ps1`. **Expected:** `DLP Policy - Retail Customer PII - Test` records the match without blocking.

Test 6 — PCI DLP blocks (after the gate)

Do: After Step 8, repeat Test 4 against `DLP Policy - Retail PCI Cardholder Data - Enforce`. **Expected:** The action **blocks** the message/share containing the test PAN; the event is logged. PAN cannot move through the enabled M365 locations.

Test 7 — Customer-PII DLP enforces (after the gate)

Do: After Step 8, repeat Test 5 against `DLP Policy - Retail Customer PII - Enforce`. **Expected:** The action blocks (or blocks-with-override) per the enforce rule; the event is logged.

Test 8 — Endpoint DLP fires (endpoint DLP only)

Do: On an onboarded pilot device, attempt to copy a test file containing a test PAN to a USB drive or upload it to a personal-cloud domain. **Expected:** The endpoint DLP rule audits (before the gate) or blocks

(after), per policy mode.

Test 9 — Retention label applied and honored

Do: Apply `Retention Label - Customer Transaction Records - 7 Year` to a test item and attempt to delete it. **Expected:** The item is retained for the period (or declared a record and blocked from deletion) per the label.

Test 10 — Retention policy scoped

Do: Confirm `Retention Policy - Retail Baseline - 5 Year` is applied to the pilot locations (Purview → **Data Lifecycle Management** → **Retention policies** → open the policy). Or run `RETAIL-Validation.ps1`. **Expected:** The policy shows **On** and scoped to the pilot mailboxes/sites/OneDrive/Teams.

Test 11 — PCI compliance evidence present

Do: Purview → **Compliance Manager** → open `Assessment - PCI-DSS - Retail Baseline`. **Expected:** The assessment exists, improvement actions map to the configured Purview controls, and evidence can be recorded. (Requires the licensing in Requirement 2.1 — **verify your tenant**.)

Test 12 — Coverage report

Do: Run `RETAIL-Report.ps1`. **Expected:** A summary of classification (labeled items), DLP location/mode coverage, and DLP events by workload — so PAN/PII coverage and gaps are visible.

Pass/fail gate

Gate	Requirement
Pilot pass	Tests 1–5, 9–10 pass on `Purview - Retail Pilot`; the DLP audit shows real PAN/PII matches and acceptable noise
Audit gate	Both DLP policies' audits reviewed and tuned; only then are Tests 6–8 (enforce/block) run
Expand pass	Tests 1, 4/6, 5/7, 10, 12 pass after widening scope beyond the pilot

6. Troubleshooting Guide — Microsoft Purview for Retail

Use `RETAIL-Discovery.ps1` for the tenant's current config, `RETAIL-Validation.ps1` to confirm the named objects are in place, `RETAIL-Report.ps1` for classification and DLP-event coverage, and `RETAIL-Configuration.ps1` (default `-WhatIf`) for safe fixes. `RETAIL-Set-Scope.ps1` builds/checks the `Purview - Retail Pilot` group.

A. Sensitivity labels not appearing for retail users

Symptom	Cause	Remediation
No Sensitivity button / labels missing	Label policy not published to the user, or publish still propagating	Confirm the user is in `Purview - Retail Pilot`; verify `Label Policy - Retail Data Classification - Pilot` targets them; allow up to 24 hours to propagate
Labels appear but no encryption	Label scoped to items but encryption not configured	Edit the label (`Sensitivity Label - Customer PII - Confidential` / `Sensitivity Label - Cardholder Data - Restricted`), enable **Configure encryption**, republish
Wrong label order/priority	Labels created out of sensitivity order	Reorder `Retail Public` → `Retail Internal` → `Customer PII - Confidential` → `Cardholder Data - Restricted`; order sets priority

B. Auto-labeling not finding cardholder data

• Confirm `Auto-Label - PCI Cardholder Data - Simulation` is running; simulation reports matches but

applies nothing (by design — leave it in simulation until reviewed).

• Auto-labeling at rest (SharePoint/OneDrive) requires the higher plan; verify licensing with

`RETAIL-Discovery.ps1` and Requirement 2.1 (**verify your licensing/tenant**).

• Check the rule uses the **Credit Card Number** SIT and that confidence/instance count is not set so

high it suppresses matches. Confirm the SIT exists via `RETAIL-Discovery.ps1`.

C. PCI/PII DLP is too noisy (false positives)

• This is expected **before** the audit gate — keep the policies in test/audit mode and tune. Common

retail noise: order numbers, SKUs, or loyalty IDs that resemble a PAN. Raise the Credit Card Number match confidence, require a higher instance count, and add exceptions for known patterns.

• Review matches in Purview → **Data Loss Prevention** → **Alerts** and **Activity explorer**; run

`RETAIL-Report.ps1`.

• Do **not** switch `DLP Policy - Retail PCI Cardholder Data - Test` or `DLP Policy - Retail Customer

PII - Test` to block until the noise is acceptable.

D. DLP not blocking after enforce

Symptom	Cause	Remediation
Enforce policy does not block PAN	Policy left in test mode, or scope excludes the user	Confirm `DLP Policy - Retail PCI Cardholder Data - Enforce` mode is **Turn the policy on**; confirm the user/location is in scope; run `RETAIL-Validation.ps1` to see the mode
Endpoint (device) rules never fire	Device not onboarded to Purview	Onboard the device (Purview → **Settings** → **Device onboarding**); verify with `RETAIL-Discovery.ps1`
Teams/SharePoint not covered	Location not enabled on the policy	Edit the policy and enable the missing location; re-run `RETAIL-Report.ps1` to confirm the coverage matrix

E. Cardholder data still found in M365 after enforcement

• Enforcement blocks **new** movement; it does not remove PAN already at rest. Use the `Auto-Label - PCI Cardholder Data - Simulation` results (Test 3) to locate existing PAN, then have the data owner remove/relocate it to the certified payment environment.

• Re-run the simulation after clean-up to confirm the location is clear. Removing existing cardholder data from out-of-scope systems is a **compliance/QSA-directed** activity — coordinate, don't delete unilaterally.

F. Retention deleting too much or nothing

• Over-deletion: confirm the duration on `Retention Policy - Retail Baseline - 5 Year` and the `Retention Label - *` end action; pilot on `Purview - Retail Pilot` before widening. Deletion is irreversible.

• Nothing retained: confirm the policy shows **On** and is scoped to the correct locations; run `RETAIL-Validation.ps1`.

• For records, enable **disposition review** so items are reviewed before deletion rather than auto-deleted. **Retention periods are set by compliance/records**, not IT.

G. PCI-DSS Compliance Manager template missing

• The PCI-DSS assessment template is a **premium** template requiring Microsoft 365 E5 / E5 Compliance;

if it is absent from **Compliance Manager** → **Assessment templates**, verify the plan (Requirement 2.1, **verify your licensing/tenant**). Compliance Manager tracks/evidences controls — it does not certify PCI compliance; certification is a QSA activity.

H. Licensing / feature missing

• Auto-labeling at rest, endpoint DLP, and the PCI-DSS Compliance Manager template require Microsoft

365 E5 or the E5 Compliance add-on. If a feature is absent from the portal, verify the plan with `RETAIL-Discovery.ps1` and Requirement 2.1.

I. Diagnostics quick reference

```
# Security & Compliance PowerShell (Exchange Online Management module)
Connect-IPPSSession
Get-Label | Select-Object DisplayName, Priority, ContentType
Get-LabelPolicy | Select-Object Name, Enabled
Get-DlpCompliancePolicy | Select-Object Name, Mode, Enabled
Get-RetentionCompliancePolicy | Select-Object Name, Enabled, Mode
Get-DlpSensitiveInformationType | Where-Object Name -match 'Credit Card'
```

For classification and DLP events, use the Purview **Activity explorer** and the unified audit log (Requirement 2.8).

J. When to escalate

If a policy is published and propagated, the user is in scope, licensing is correct, and labels still do not appear (or DLP still does not act) after 24 hours and a `RETAIL-Configuration.ps1` run, collect the output of `RETAIL-Discovery.ps1` and `RETAIL-Validation.ps1` and open a Microsoft support case.

7. Best Practices — Microsoft Purview for Retail

• **Keep cardholder data out of M365 — don't try to make M365 PCI-compliant.** The right retail posture

is that Exchange, SharePoint, OneDrive, Teams, and endpoints stay **out** of PCI-DSS scope. Use DLP to **block PAN** from landing there; keep the certified cardholder-data environment separate. Purview reduces the chance of stray PAN, it does not certify M365 for cardholder data.

• **Audit DLP before you enforce.** The single most important practice: run both the PCI and PII

policies in test/audit, review the matches, tune out false positives (order numbers that resemble a PAN, internal PII in HR content), and only then switch to block. A false block at a checkout or fulfilment desk is the fastest way to lose trust in DLP.

• **Simulate auto-labeling first.** Run `Auto-Label - PCI Cardholder Data - Simulation` and treat the

results as your **PAN discovery map** — it shows where cardholder data is actually sitting in M365 so it can be removed and the scope kept small. Only turn it on after the simulation is clean.

- **Block PAN outright; override PII by exception.** Cardholder data generally has no legitimate reason to move through M365 — block it. Customer PII does move for legitimate retail operations — prefer block-with-override (with business justification) so staff aren't stopped from doing real work.
- **Minimize payment-data retention.** PCI-DSS favors keeping cardholder data to a minimum. Set `Retention Label - Payment Records - 18 Month` (or the compliance-approved period) short and dispose defensibly — over-retention of payment data is itself a finding.
- **Keep the taxonomy small and retail-legible.** Four labels store, e-commerce, and head-office staff can reason about beats a dozen nobody uses. Name each plainly and give a clear tooltip; make the `Cardholder Data - Restricted` label unmistakable.
- **Tune with confidence levels and instance counts.** Reduce false positives by raising the match confidence on the Credit Card Number SIT and requiring a minimum instance count rather than a single hit.
- **Name every object by purpose and stage.** Use `<Purpose> - <Scope> - <Stage>` (for example rename `DLP Policy - Retail PCI Cardholder Data - Test` to `... - Enforce` at the gate) so the portal shows exactly where each policy is in its lifecycle.
- **Pilot retention before it deletes.** Retention deletion is irreversible; validate `Retention Policy - Retail Baseline - 5 Year` on `Purview - Retail Pilot` first, and use disposition review for records so nothing is auto-deleted unreviewed.
- **Evidence PCI controls continuously.** Track the classification, DLP, and retention controls in `Assessment - PCI-DSS - Retail Baseline` and report coverage with `RETAIL-Report.ps1` — auditors want evidence the controls operate, not just that they exist.
- **Defer the determinations.** PCI scope, applicable requirements, records schedules, and retention periods are compliance/QSA/records/legal decisions. Configure and evidence; don't decide.

8. Deliverables Summary — Microsoft Purview for Retail

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What the retail Purview program delivers — labels, auto-labeling, PCI + PII DLP, retention/records, PCI-DSS compliance baseline — benefits, limitations, and the PCI-scope posture

Document	Purpose
2. Requirements Guide	Every prerequisite with Verify / Implement-if-missing (retail-/PCI-specific, on top of the category GR)
Global Requirements (Purview)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered Purview portal steps (labels, label policy, auto-label simulation, PCI + PII DLP audit-then-block, retention/records, PCI-DSS Compliance Manager)
5. Testing Guide	Validation procedures with pass/fail gates and the DLP audit gate (synthetic/test data only)
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations for a retail/PCI rollout

PowerShell scripts

Script	What it does
`RETAIL-Discovery.ps1`	Reports the tenant's sensitivity labels, DLP policies (PCI/PII, mode), retention policies, the Credit Card Number + PII sensitive-info types, and endpoint/licensing signals
`RETAIL-Configuration.ps1`	Safe remediation/config helper (default `-WhatIf`) — enables a published-but-off label policy and a disabled retention policy; **never** auto-switches DLP to block (the audit gate is a human decision)
`RETAIL-Validation.ps1`	Confirms the expected labels are published, both DLP policies (PCI + PII) exist and reports their mode, and the retention policy exists and is on
`RETAIL-Report.ps1`	Classification + DLP-event coverage summary across the enabled services (PAN/PII by workload)
`RETAIL-Set-Scope.ps1`	Builds/updates the `Purview - Retail Pilot` Entra group and runs a quick scope/health check

What the buyer receives

- This implementation guide as a Word document and PDF.
- All five PowerShell scripts in a single ZIP.
- A repeatable process following the model: **Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand (enforce)**, with a DLP audit gate before any policy blocks and a documented rollback.

Outcome

A Retail-tailored Microsoft Purview program — a clear label taxonomy, auto-labeling that maps where PAN lives, PCI and customer-PII DLP tuned in audit before it blocks, retention that meets the retail records schedule while minimizing payment-data storage, and a PCI-DSS compliance baseline — configured, piloted, validated, and evidenced, with all regulatory/PCI/records determinations left to the organization's compliance, QSA, records, privacy, and legal functions.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

RETAIL-Configuration.ps1

Purpose: Remediates the low-risk gaps RETAIL-Validation.ps1 finds — enabling a published-but-off label policy and enabling a disabled retention policy — WITHOUT ever switching a DLP policy to enforce/block (that is the audit gate, a human decision, and blocking PAN/PII is high-impact). Runs in -WhatIf (preview) by default; pass -Apply to make changes. It never deletes anything and never enables Enforce/Block mode on DLP; it only reports DLP policies still in test/audit. HOW TO RUN Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\RETAIL-Configuration.ps1 Apply changes: powershell -ExecutionPolicy Bypass -File .\RETAIL-Configuration.ps1 -Apply Sign in as a Compliance Administrator when prompted. EXPECTED RESULTS A list of proposed actions (WhatIf) or the applied changes (-Apply). DLP enforce/block is never automated — the script only lists PCI/PII DLP policies still in test/audit for the operator to promote via the Implementation Guide (Step 8) after the audit gate. .NOTES White-label — Purview / Retail. Default is a dry run. PowerShell 5.1+/7+. Uses Get-/Set-LabelPolicy and Get-/Set-RetentionCompliancePolicy; reads Get-DlpCompliancePolicy. Does not create/delete objects. > [CmdletBinding()] param([switch]$Apply, [string]$LabelPolicyName = 'Label Policy - Retail Data Classification - Pilot', [string]$RetentionPolicyName = 'Retention Policy - Retail Baseline - 5 Year') $WhatIf = -not $Apply $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'APPLY'})

How to run: Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\RETAIL-Configuration.ps1 Apply changes: powershell -ExecutionPolicy Bypass -File .\RETAIL-Configuration.ps1 -Apply Sign in as a Compliance Administrator when prompted. EXPECTED RESULTS A list of proposed actions (WhatIf) or the applied changes (-Apply). DLP enforce/block is never automated — the script only lists PCI/PII DLP policies still in test/audit for the operator to promote via the Implementation Guide (Step 8) after the audit gate. .NOTES White-label — Purview / Retail. Default is a dry run. PowerShell 5.1+/7+. Uses Get-/Set-LabelPolicy and Get-/Set-RetentionCompliancePolicy; reads Get-DlpCompliancePolicy. Does not create/delete objects. > [CmdletBinding()] param([switch]$Apply, [string]$LabelPolicyName = 'Label Policy - Retail Data Classification - Pilot', [string]$RetentionPolicyName = 'Retention Policy - Retail Baseline - 5 Year') $WhatIf = -not $Apply $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'APPLY'})

RETAIL-Discovery.ps1

Purpose: Connects to Security & Compliance PowerShell and reports the Microsoft Purview configuration a retail/PCI program cares about: sensitivity labels and label policies, DLP policies (with mode: test/audit vs enforce) and whether they cover the Credit Card Number / PII sensitive- information types, retention labels/policies, and the presence of the built-in Credit Card Number SIT. This is the "what exists today" read used to plan the taxonomy, the DLP audit gate, and retention scope. HOW TO RUN Install-Module ExchangeOnlineManagement -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\RETAIL-Discovery.ps1 Sign in as a Compliance Administrator (or Information Protection + DLP roles) when prompted. EXPECTED RESULTS Lists of sensitivity labels (name, priority, encryption), label policies, DLP policies (name, MODE — flags any already enforcing), retention labels/policies, and a check that the built-in Credit Card Number sensitive-info type is present. Nothing is changed. .NOTES White-label — Purview / Retail. Read-only. PowerShell 5.1+/7+. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy / Get-ComplianceTag / Get-DlpSensitiveInformationType. > [CmdletBinding()] param()

How to run: Install-Module ExchangeOnlineManagement -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\RETAIL-Discovery.ps1 Sign in as a Compliance Administrator (or Information Protection + DLP roles) when prompted. EXPECTED RESULTS Lists of sensitivity labels (name, priority, encryption), label policies, DLP policies (name, MODE — flags any already enforcing), retention labels/policies, and a check that the built-in Credit Card Number sensitive-info type is present. Nothing is changed. .NOTES White-label — Purview / Retail. Read-only. PowerShell 5.1+/7+. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy / Get-ComplianceTag / Get-DlpSensitiveInformationType. > [CmdletBinding()] param()

RETAIL-Report.ps1

Purpose: Summarizes retail information-protection coverage so you can review the DLP audit gate and track classification: (1) which sensitivity labels exist and their protection, (2) which services each DLP policy covers and its mode (flagging the retail PCI/PII policies), and (3) recent DLP events from the unified audit log grouped by workload — the audit data you tune before blocking PAN and customer PII. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\RETAIL-Report.ps1 -Days 7 -CsvPath C:\Temp\retail-dlp.csv Sign in as a Compliance Administrator when prompted. Requires audit logging enabled (Requirement 2.8) for the DLP-event section to return data. EXPECTED RESULTS A label inventory, a DLP location/mode matrix (with a Retail/PCI flag), and a per-workload count of DLP rule matches for the window, optionally exported to CSV. Nothing is changed. .NOTES White-label — Purview / Retail. Read-only. PowerShell 5.1+/7+. Uses Get-Label / Get-DlpCompliancePolicy and Search-UnifiedAuditLog (RecordType DLP). > [CmdletBinding()] param([int]$Days = 7, [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\RETAIL-Report.ps1 -Days 7 -CsvPath C:\Temp\retail-dlp.csv Sign in as a Compliance Administrator when prompted. Requires audit logging enabled (Requirement 2.8) for the DLP-event section to return data. EXPECTED RESULTS A label inventory, a DLP location/mode matrix (with a Retail/PCI flag), and a per-workload count of DLP rule matches for the window, optionally exported to CSV. Nothing is changed. .NOTES White-label — Purview / Retail. Read-only. PowerShell 5.1+/7+. Uses Get-Label / Get-DlpCompliancePolicy and Search-UnifiedAuditLog (RecordType DLP). > [CmdletBinding()] param([int]$Days = 7, [string]$CsvPath)

RETAIL-Set-Scope.ps1

Purpose: Creates (or updates) the Microsoft Entra security group this solution targets its labels, DLP, and retention at — the pilot scope 'Purview - Retail Pilot' — and adds the supplied members. Then it reports the group's current membership count as a quick scope/health check. Use it to stand up Requirement 2.6 before publishing any policy, and to widen scope during Expand. Supports -WhatIf: previews without changing anything. HOW TO RUN Install-Module Microsoft.Graph -Scope CurrentUser Preview: powershell -ExecutionPolicy Bypass -File .\RETAIL-Set-Scope.ps1 -Members user1@contoso.com,user2@contoso.com -WhatIf Apply: powershell -ExecutionPolicy Bypass -File .\RETAIL-Set-Scope.ps1 -Members user1@contoso.com,user2@contoso.com Sign in with rights to create groups (Groups Administrator) when prompted. EXPECTED RESULTS The group exists (created if missing), the named members are added, and a membership-count health line is printed. -WhatIf previews without changing anything. .NOTES White-label — Purview / Retail. PowerShell 5.1+/7+. Uses Microsoft Graph PowerShell (Get-/New-MgGroup / New-MgGroupMemberByRef). > [CmdletBinding(SupportsShouldProcess=$true)] param([string]$GroupName = 'Purview - Retail Pilot', [string[]]$Members = @())

How to run: Install-Module Microsoft.Graph -Scope CurrentUser Preview: powershell -ExecutionPolicy Bypass -File .\RETAIL-Set-Scope.ps1 -Members user1@contoso.com,user2@contoso.com -WhatIf Apply: powershell -ExecutionPolicy Bypass -File .\RETAIL-Set-Scope.ps1 -Members user1@contoso.com,user2@contoso.com Sign in with rights to create groups (Groups Administrator) when prompted. EXPECTED RESULTS The group exists (created if missing), the named members are added, and a membership-count health line is printed. -WhatIf previews without changing anything. .NOTES White-label — Purview / Retail. PowerShell 5.1+/7+. Uses Microsoft Graph PowerShell (Get-/New-MgGroup / New-MgGroupMemberByRef). > [CmdletBinding(SupportsShouldProcess=$true)] param([string]$GroupName = 'Purview - Retail Pilot', [string[]]$Members = @())

RETAIL-Validation.ps1

Purpose: Verifies the named objects this solution deploys are present and in the expected state: the retail sensitivity-label taxonomy is published, BOTH the PCI cardholder-data and customer-PII DLP policies exist (and reports each mode so you can see whether it has passed the audit gate into enforce/block), and the retention policy exists and is enabled. Pass/fail per the Testing Guide. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\RETAIL-Validation.ps1 Sign in as a Compliance Administrator when prompted. Optionally pass -PciDlpName / -PiiDlpName / -RetentionPolicyName / -LabelPolicyName to match your renamed objects. EXPECTED RESULTS "VALIDATION PASSED" when the label policy is enabled, both DLP policies are present, and the retention policy is enabled. Exit code 0 on pass, 1 on any gap. .NOTES White-label — Purview / Retail. Read-only. PowerShell 5.1+/7+. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy. > [CmdletBinding()] param([string]$LabelPolicyName = 'Label Policy - Retail Data Classification - Pilot', [string]$PciDlpName = 'DLP Policy - Retail PCI Cardholder Data', [string]$PiiDlpName = 'DLP Policy - Retail Customer PII', [string]$RetentionPolicyName = 'Retention Policy - Retail Baseline - 5 Year')

How to run: powershell -ExecutionPolicy Bypass -File .\RETAIL-Validation.ps1 Sign in as a Compliance Administrator when prompted. Optionally pass -PciDlpName / -PiiDlpName / -RetentionPolicyName / -LabelPolicyName to match your renamed objects. EXPECTED RESULTS "VALIDATION PASSED" when the label policy is enabled, both DLP policies are present, and the retention policy is enabled. Exit code 0 on pass, 1 on any gap. .NOTES White-label — Purview / Retail. Read-only. PowerShell 5.1+/7+. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy. > [CmdletBinding()] param([string]$LabelPolicyName = 'Label Policy - Retail Data Classification - Pilot', [string]$PciDlpName = 'DLP Policy - Retail PCI Cardholder Data', [string]$PiiDlpName = 'DLP Policy - Retail Customer PII', [string]$RetentionPolicyName = 'Retention Policy - Retail Baseline - 5 Year')